

Inventaire des Actifs Informationnels — TechShop SAS

Version : 1.0

Date : Juin 2026

Auteur : Dorian Poncelet (Consultant GRC)

Statut : Validé

Référence : ISO 27001:2022 — Clause 8.1 / Annex A.5.9 & A.5.10

Méthode de classification

Pourquoi classer les actifs ?

La classification sert à **calibrer les mesures de sécurité** en fonction de la valeur réelle de l'actif. Mettre le même niveau de protection sur les données clients (confidentielles, RGPD) et sur la liste des fournisseurs de fournitures de bureau serait inefficace et coûteux.

ISO 27001:2022 (A.5.9) exige un inventaire des actifs. ISO 27001:2022 (A.5.12) exige leur classification. Ces deux contrôles sont liés : on ne peut pas classer ce qu'on n'a pas inventorié.

Taxonomie EBIOS RM — Types d'actifs

EBIOS RM distingue deux niveaux :

Valeurs métier (ce qu'on protège vraiment) :

- Données : informations structurées ou non
- Processus : activités opérationnelles critiques
- Savoir-faire : compétences, configurations, procédures

Actifs support (ce qui porte les valeurs métier) :

- Matériel : serveurs, postes, équipements réseau
- Logiciel : applications, OS, middleware
- Service externe : SaaS, cloud, infogérance
- Réseau : infrastructure de communication
- Personnel : compétences humaines critiques
- Locaux : sites physiques

Échelle de valeur (1 à 5)

Valeur	Signification	Critère principal
5	Critique	Indisponibilité = arrêt total de l'activité ou amende CNIL majeure
4	Élevée	Indisponibilité = perte CA significative ou risque juridique
3	Importante	Indisponibilité = dégradation notable du service
2	Modérée	Indisponibilité = gêne opérationnelle sans impact client
1	Faible	Indisponibilité = inconfort interne mineur

Niveaux de classification

Niveau	Définition	Exemples
Public	Information librement accessible	Site web, catalogue produits
Interne	Usage interne uniquement, pas de préjudice si divulguée	Procédures internes, organigramme
Confidentiel	Divulgence = préjudice commercial ou opérationnel	Contrats fournisseurs, données RH
Secret	Divulgence = préjudice grave ou sanction légale	Données clients (RGPD), données bancaires

Note RGPD : Toute donnée à caractère personnel (Art. 4 RGPD) est classifiée **Secret** par défaut chez TechShop SAS, car sa divulgation expose à des sanctions CNIL pouvant atteindre 4% du CA mondial.

Inventaire complet

A — Données (Valeurs métier)

ID	Nom de l'actif	Type	Propriétaire	Classification	Localisation	Valeur	RGPD
A-001	Base de données clients (15 000 personnes)	Données personnelles	DPO (Sophie Blanc)	Secret	MySQL / VPS OVH + backup AWS S3 eu-west-3	5	Oui
A-002	Historique des commandes	Données transactionnelles	DSI (Thomas Rivet)	Secret	MySQL Woo Commerce / VPS OVH	5	Oui
A-003	Données RH — 47 salariés	Données personnelles sensibles	DRH	Secret	Odoo HR + Google Workspace	5	Oui

ID	Nom de l'actif	Type	Propriétaire	Classification	Localisation	Valeur	RGPD
A-004	Données bancaires (tokens Stripe)	Données financières	DSI	Secret	Stripe (externalisé — SAQ A)	5	Oui
A-005	Catalogue produits et tarifs	Données commerciales	Responsable e-commerce	Interne	WooCommerce + Odoo	3	Non
A-006	Contrats fournisseurs et partenaires	Données juridiques	Direction Générale	Confidentiel	Google Drive (Workspace)	4	Non
A-007	Données analytics (comportement visiteurs)	Données techniques	DSI	Confidentiel	Google Analytics + Grafana	3	Partiel
A-008	Données prospects CRM	Données commerciales	Responsable marketing	Confidentiel	HubSpot Free (SaaS)	3	Oui
A-009	Sauvegardes complètes (BDD + fichiers)	Données de sauvegarde	DSI	Secret	AWS S3 eu-west-3 + us-east-1 (!!)	5	Oui
A-010	Journaux d'accès et logs sécurité	Données techniques	DSI	Confidentiel	Grafana + Prometheus / VPS OVH	4	Partiel

B — Applications et Logiciels (Actifs support)

ID	Nom de l'actif	Type	Propriétaire	Classification	Localisation	Valeur	RGPD
A-011	WooCommerce (site e-commerce)	Application web	DSI	Confidentiel	VPS OVH (2 serveurs)	5	Oui
A-012	Odoo 17 Community (ERP)	Application métier	DSI	Confidentiel	Cloud OVH	5	Oui
A-013	Google Workspace (email + docs)	Service SaaS	DSI	Confidentiel	Google Cloud (UE)	4	Oui
A-014	HubSpot Free (CRM)	Service SaaS	Resp. marketing	Confidentiel	HubSpot Cloud (US)	3	Oui
A-015	Stripe (paiement en ligne)	Service SaaS critique	DSI	Secret	Stripe Cloud (US — PCI-DSS)	5	Oui
A-016	PayPal (paiement alternatif)	Service SaaS	DSI	Confidentiel	PayPal Cloud (US)	3	Oui

ID	Nom de l'actif	Type	Propriétaire	Classification	Localisation	Valeur	RGPD
A-017	Cloudflare (CDN + WAF)	Service SaaS sécurité	DSI	Confidentiel	Cloudflare (mondial)	4	Non
A-018	Grafana + Prometheus (supervision)	Application monitoring	DSI	Interne	VPS OVH	3	Non

C — Matériel et Infrastructure (Actifs support)

ID	Nom de l'actif	Type	Propriétaire	Classification	Localisation	Valeur	RGPD
A-019	Serveurs VPS OVH (WooCommerce)	Serveur physique/virtuel	DSI	Confidentiel	Datacenter OVH Roubaix	5	Oui
A-020	Serveur Cloud OVH (Odoo ERP)	Serveur virtuel	DSI	Confidentiel	Datacenter OVH Strasbourg	5	Oui
A-021	AWS S3 (stockage sauvegarde)	Stockage cloud	DSI	Secret	AWS eu-west-3 (Paris) + us-east-1 [!]	5	Oui
A-022	Postes de travail employés (47)	Matériel	DSI	Interne	Toulouse (siège)	3	Oui
A-023	VPN WireGuard (accès admin)	Infrastructure réseau	DSI	Confidentiel	VPS OVH	4	Non

D — Personnel (Actifs support critiques)

ID	Nom de l'actif	Type	Propriétaire	Classification	Localisation	Valeur	RGPD
A-024	Comptes d'administration (root/admin)	Accès privilégiés	RSSI	Secret	Google Workspace + OVH + AWS	5	Non
A-025	Compétences DSI (Thomas Rivet)	Savoir-faire	Direction	Confidentiel	Interne	4	Non
A-026	Procédures de reprise après sinistre	Documentation	DSI	Confidentiel	Google Drive	4	Non

Synthèse et cartographie

Répartition par classification

Classification	Nombre	%	Mesures requises
Secret	10	38%	Chiffrement, accès restreint, journalisation, RGPD
Confidentiel	11	42%	Contrôle d'accès, NDA, sauvegarde chiffrée
Interne	4	15%	Accès authentifié, pas de diffusion externe
Public	1	4%	Aucune restriction

Actifs à valeur maximale (5/5) — Surveillance prioritaire

ID	Actif	Risque principal
A-001	Base de données clients	Fuite RGPD -> amende CNIL
A-002	Historique commandes	Ransomware -> perte CA
A-003	Données RH	Fuite -> litiges prud'homaux
A-004	Tokens Stripe	Fraude -> perte de confiance
A-009	Sauvegardes S3	Non-conformité RGPD (us-east-1)
A-011	WooCommerce	Indisponibilité -> arrêt ventes
A-012	Odoo ERP	Indisponibilité -> paralysie opérationnelle
A-015	Stripe (service)	Indisponibilité -> 0 paiement possible
A-019	Serveurs OVH	Ransomware / panne
A-020	Serveur Odoo	Ransomware / panne
A-021	AWS S3	Non-conformité + perte sauvegarde
A-024	Comptes admin	Compromission = contrôle total SI

Points d'attention RGPD

[!] **A-009 / A-021 — AWS us-east-1** : Des sauvegardes contenant des données personnelles (clients, RH) sont répliquées sur us-east-1 (Virginie, USA). Ce transfert hors UE **n'est pas couvert par des clauses contractuelles types (SCC)** documentées. **Action requise** : Migrer vers eu-west-3 (Paris) ou documenter les garanties RGPD (Art. 46).

[!] **A-014 — HubSpot Free (US)** : Les données prospects sont stockées sur des serveurs américains. La version Free ne propose pas de DPA (Data Processing Agreement). **Action requise** : Passer à HubSpot Starter (DPA disponible) ou migrer vers un CRM EU.

Traçabilité

Référence	Contrôle ISO 27001:2022
Inventaire des actifs	A.5.9 — Inventory of information and other associated assets
Propriété des actifs	A.5.10 — Acceptable use of information and other associated assets
Classification	A.5.12 — Classification of information
Étiquetage	A.5.13 — Labelling of information
Transferts hors UE	A.5.33 — Protection of records (+ RGPD Art. 46)

Document produit dans le cadre du SMSI TechShop SAS — Projet portfolio GRC Automation

Prochaine révision : Décembre 2026